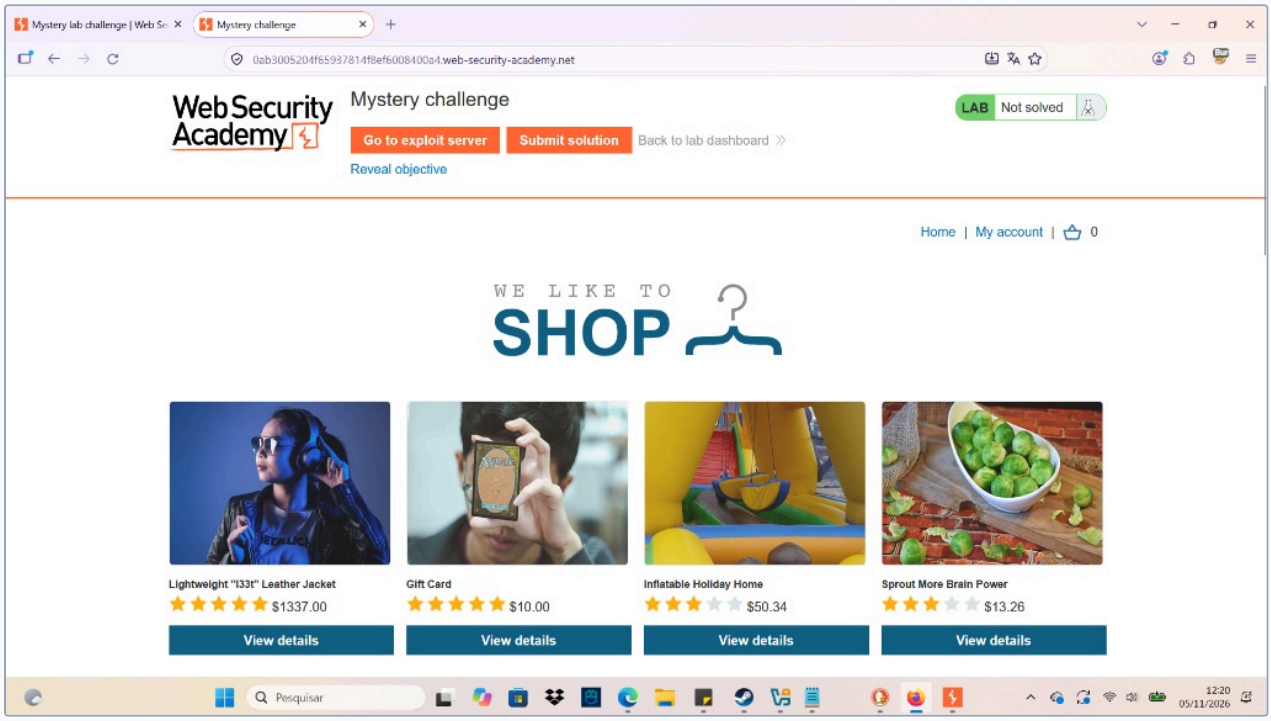
Lab: Infinite money logic flaw

PORTSWIGGER WEB SECURITY ACADEMY - REGISTRO DE RESOLUÇÃO

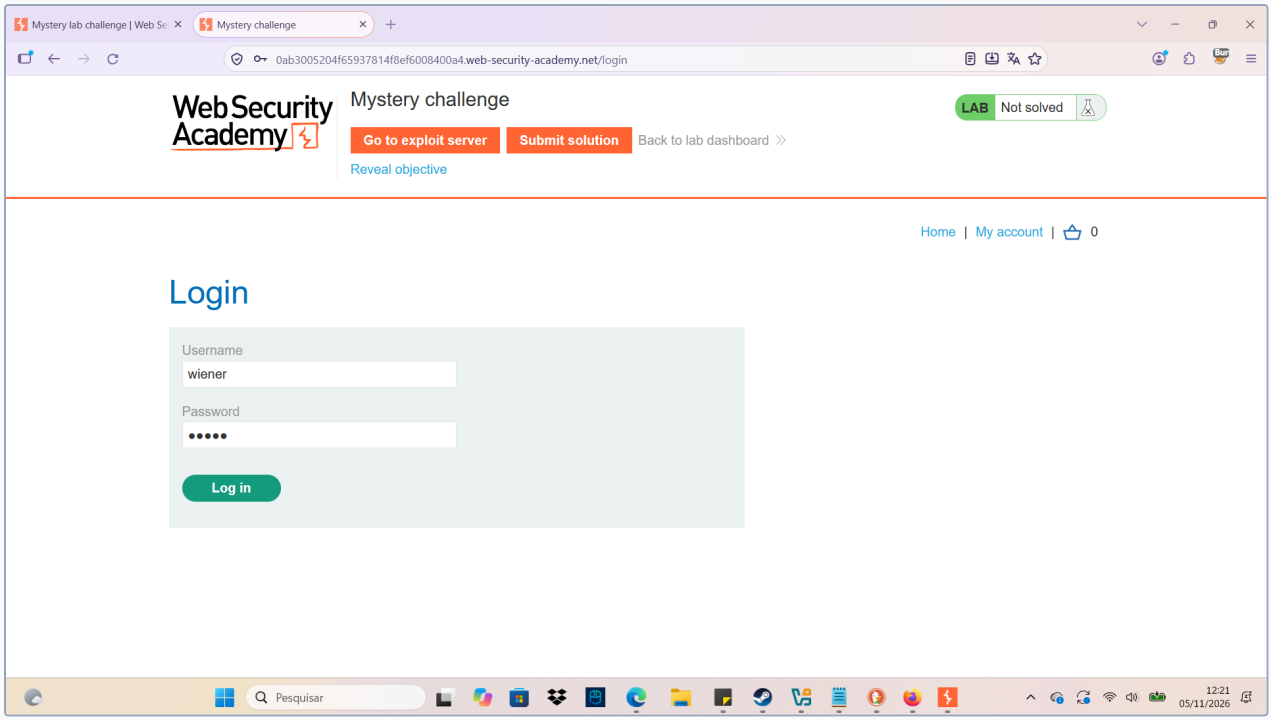
As imagens a seguir documentam, passo a passo, a exploração de uma falha de lógica financeira ("Infinite money logic flaw"). A aplicação é uma loja virtual onde novos usuários recebem um crédito inicial de $100,00. O laboratório possui uma falha de lógica na compra e resgate de cartões-presente (Gift Cards): cada Gift Card custa $10,00, mas ao ser aplicado na conta através de um código de desconto/resgate combinado com cupons de cadastro (como o `SIGNUP30`), gera um ciclo rentável contínuo. Como a versão utilizada do Burp Suite foi a Community, foi desenvolvido um script automatizado em Python (integrado com o auxílio da IA Claude) no ambiente Spyder para executar a sequência repetitiva de compras, extração de códigos e resgates automáticos até atingir o saldo de $1337,00 necessário para adquirir a jaqueta "Lightweight 133t Leather Jacket".

1. Página Inicial da Loja e Alvo do Ataque



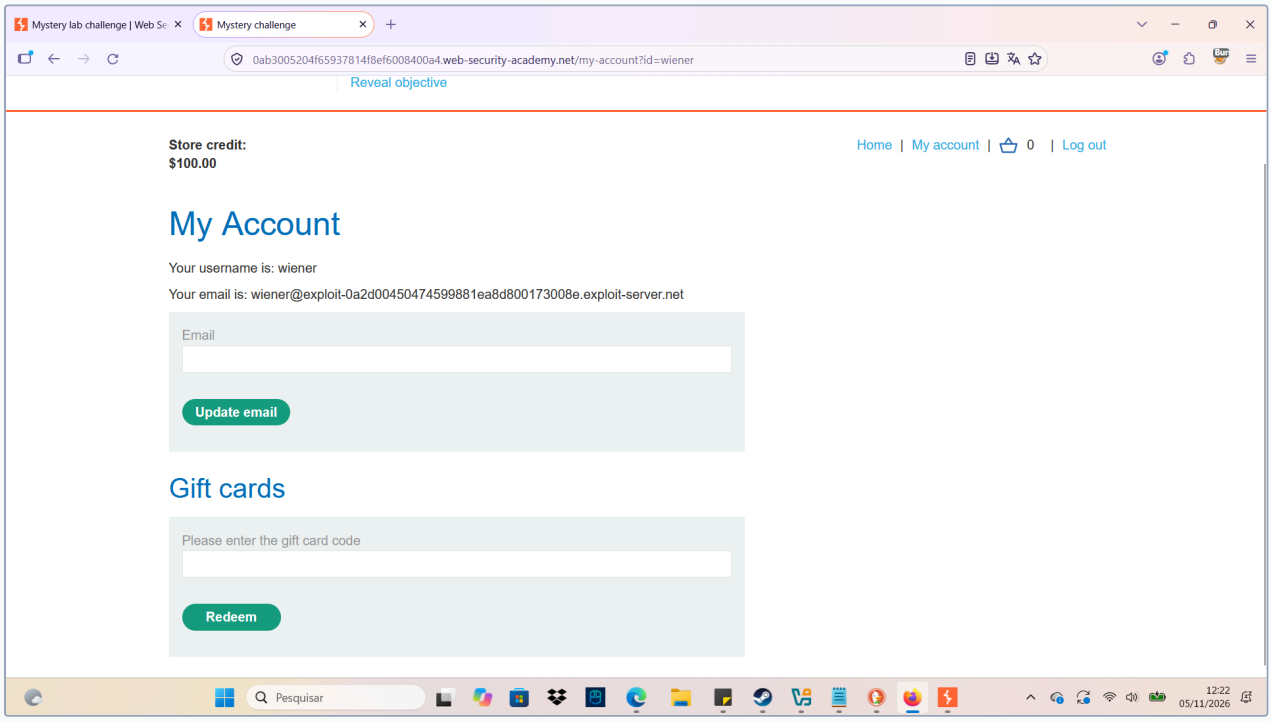
Visão inicial da loja virtual fictícia ("Mystery challenge") exibindo os produtos à venda. Entre os itens disponíveis destaca-se a jaqueta "Lightweight 133t Leather Jacket", cujo valor original de $1337,00 é o objetivo final da exploração.

2. Autenticação na Aplicação



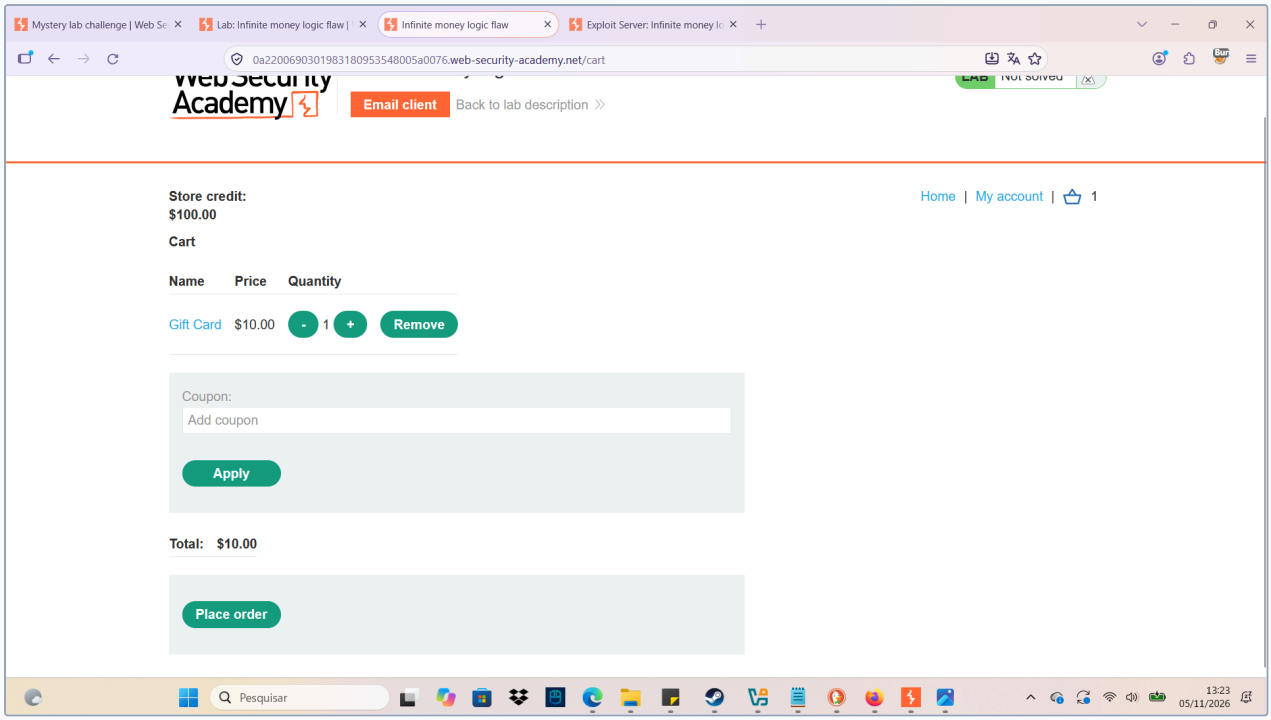
Tela de login da loja virtual. O acesso ao sistema é realizado utilizando as credenciais padrão de teste fornecidas pelo laboratório (`wiener:peter`).

3. Verificação do Saldo Inicial na Conta



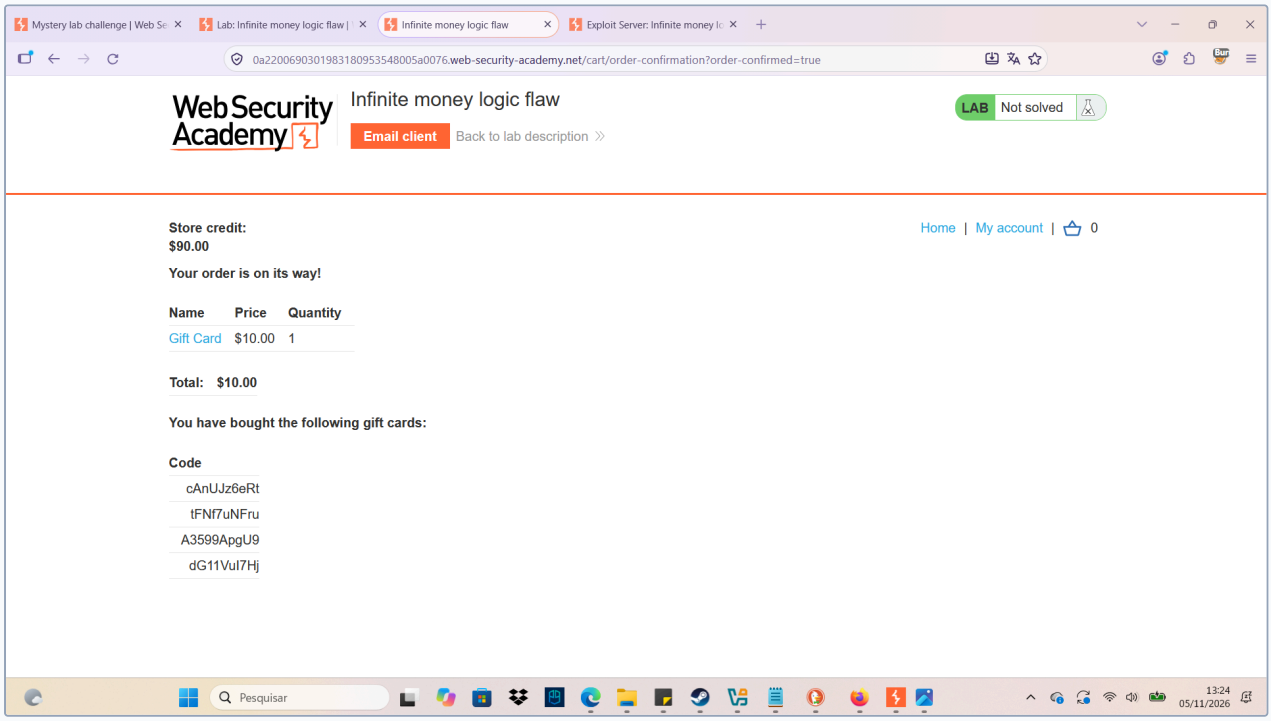
Painel da conta (`My Account`) autenticado como usuário `wiener`. É confirmado o crédito inicial de $100,00 concedido pela loja e a seção de resgate de Gift Cards.

4. Adição do Gift Card ao Carrinho



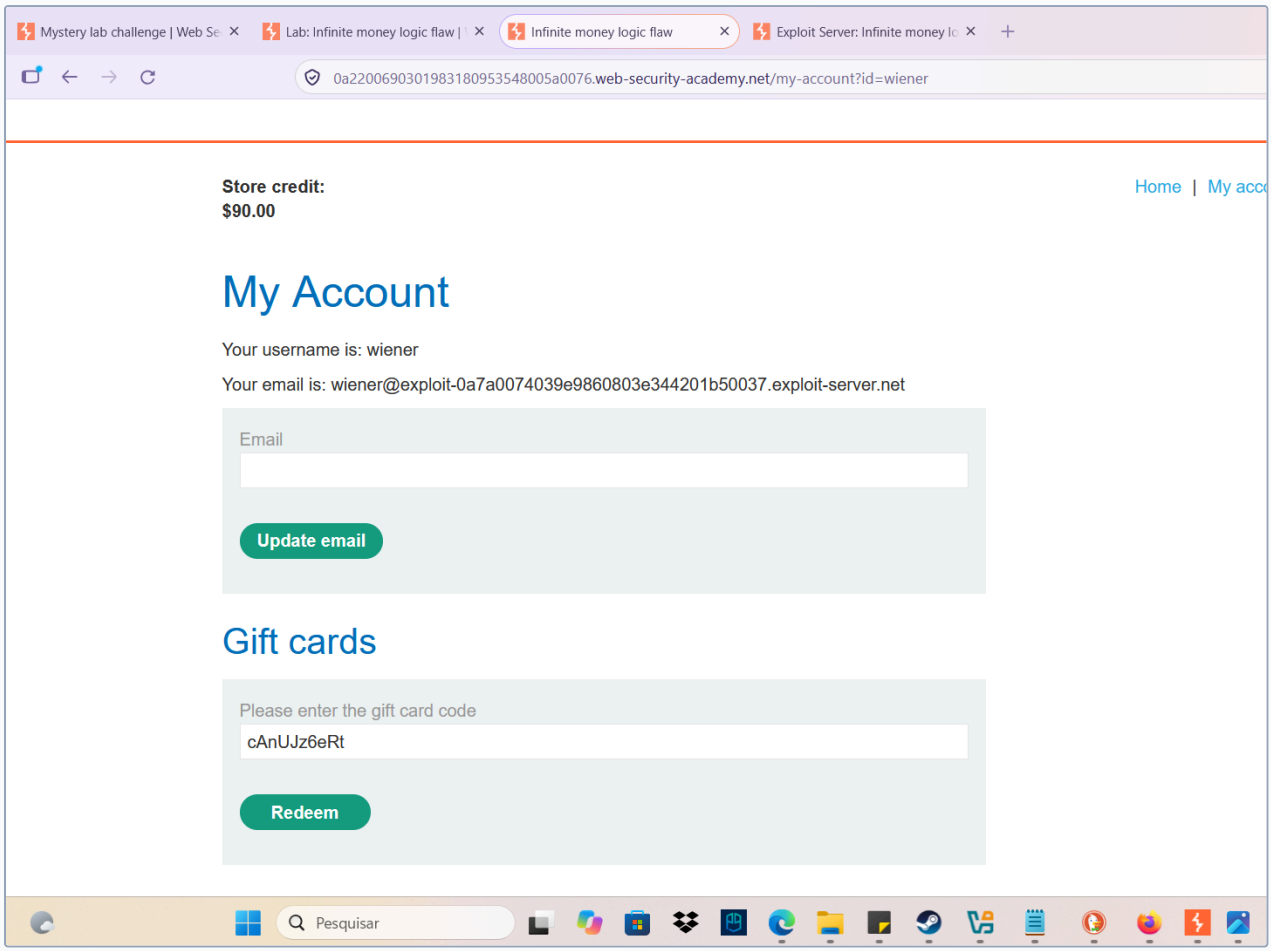
Adição de 1 unidade do produto "Gift Card" (no valor nominal de $10,00) ao carrinho de compras para validar o fluxo manual de checkout.

5. Confirmação do Pedido e Geração dos Códigos



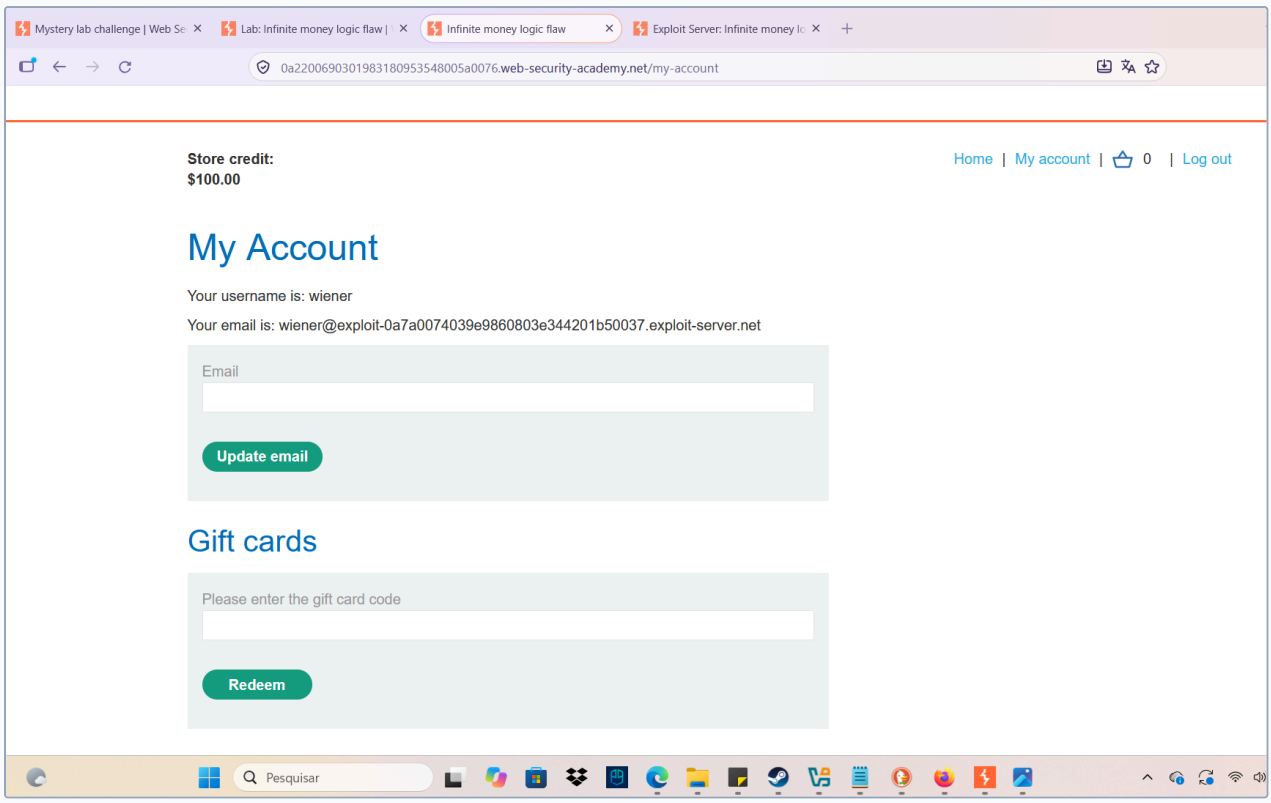
Confirmação da compra efetuada com sucesso. O servidor debita $10,00 do saldo (restando $90,00) e retorna uma lista de códigos únicos referente aos cartões-presente adquiridos.

6. Teste Manual de Resgate do Código



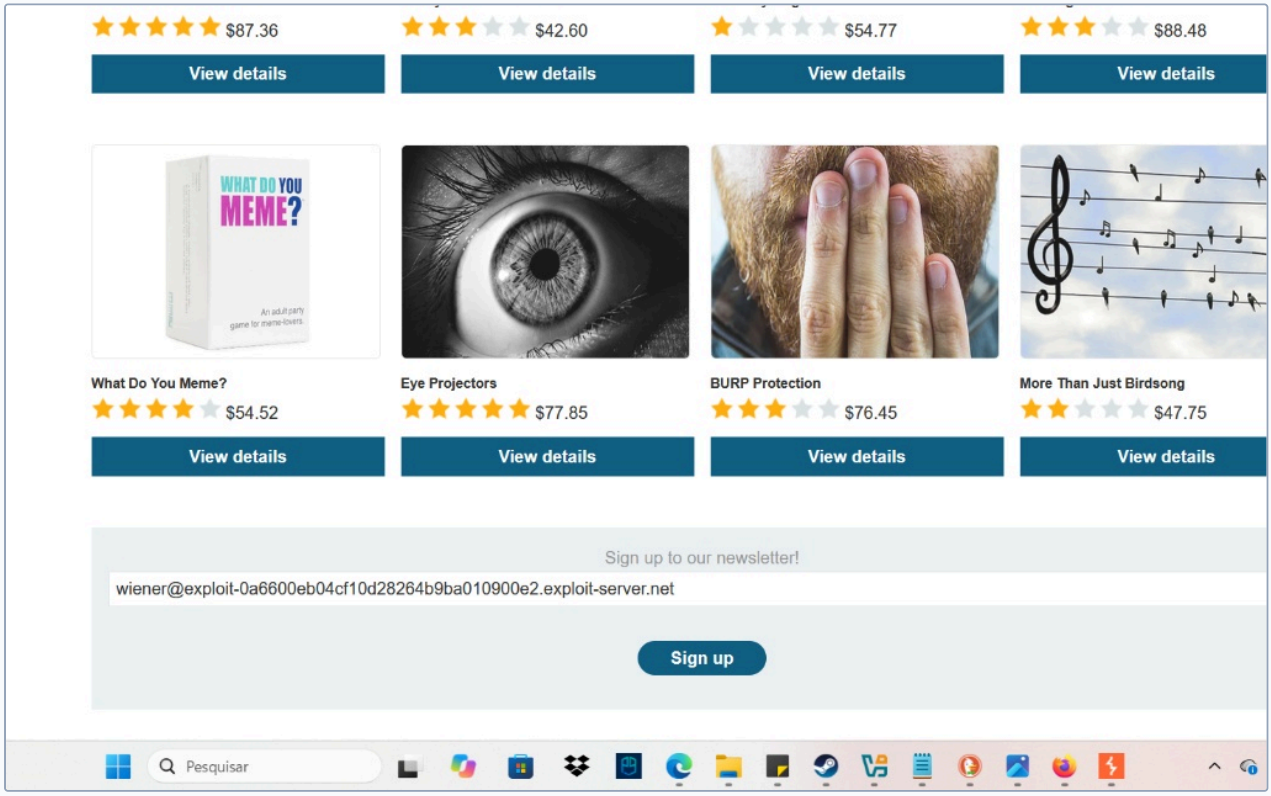
Inserção manual de um dos códigos de Gift Card obtidos (ex: `cAnUJz6eRt`) no campo de resgate do painel da conta para verificar se o crédito retorna integralmente à carteira.

7. Validação do Retorno de Crédito



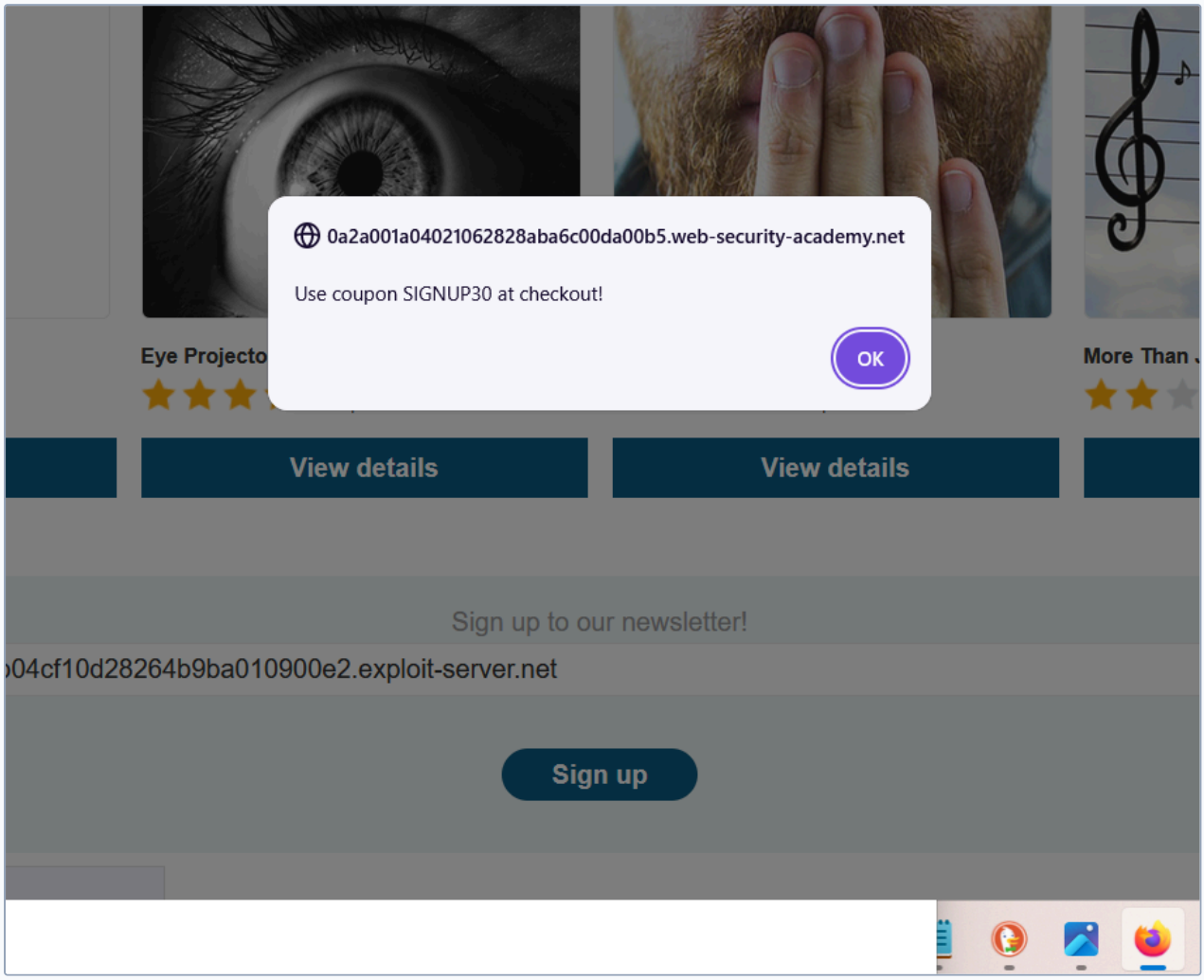
Após o envio do código de resgate, o saldo retorna a $100,00, provando que o resgate de um Gift Card de $10,00 restaura exatamente seu valor facial.

8. Inscrição na Newsletter da Loja



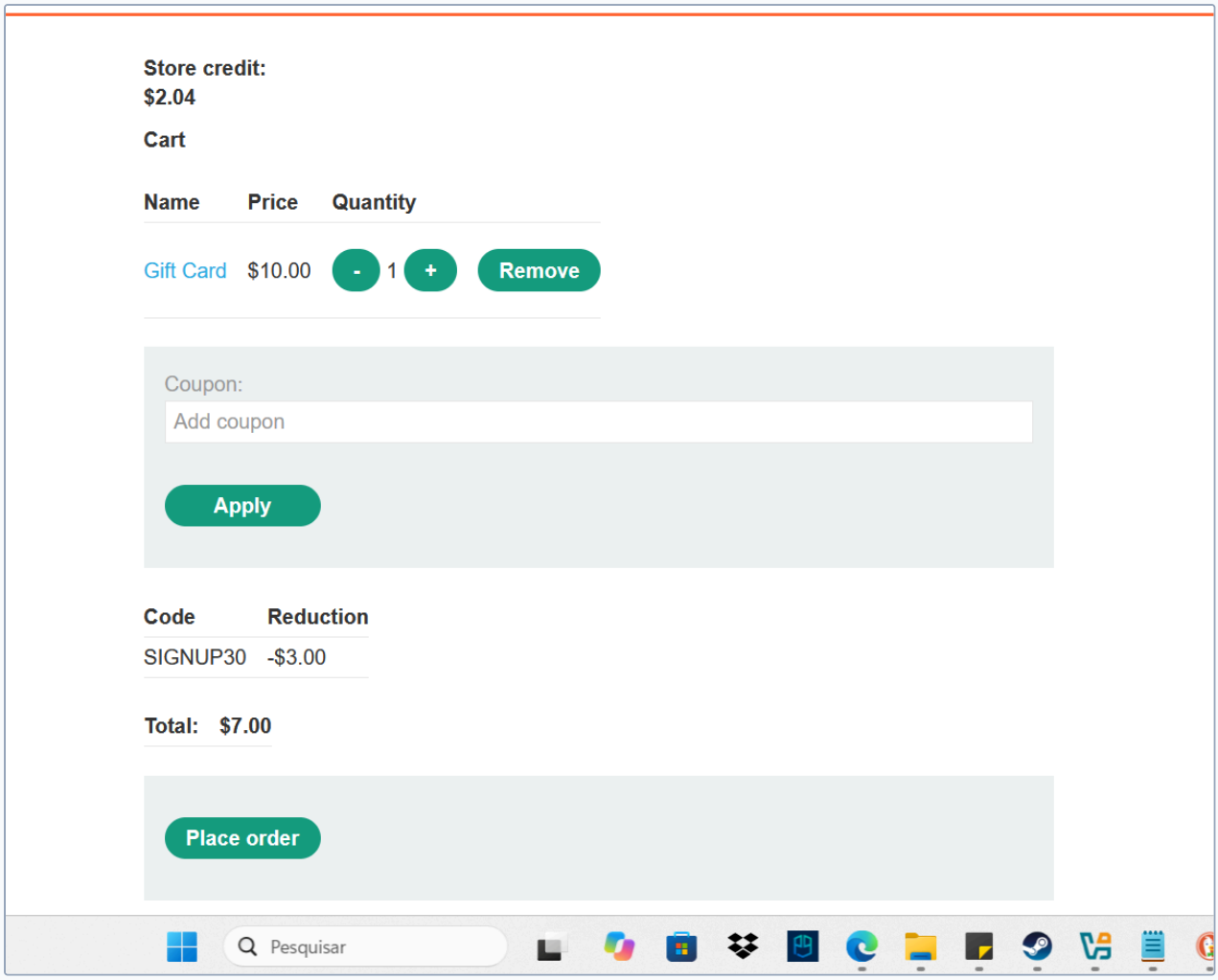
Navegação até o rodapé da loja e cadastro do e-mail do usuário no formulário de inscrição da newsletter para desencadear o envio de cupons promocionais.

9. Obtenção do Cupom Promocional SIGNUP30



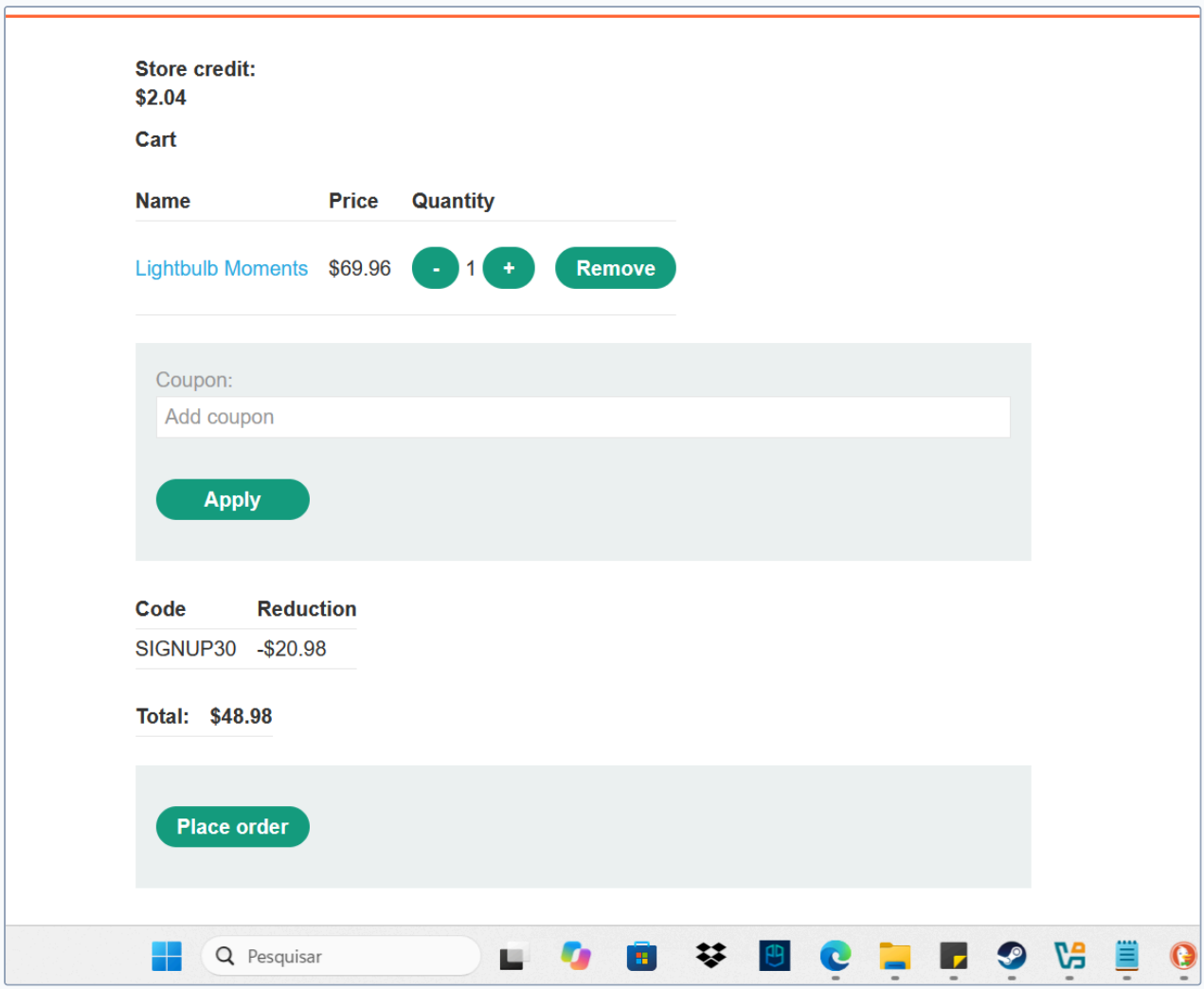
O servidor aceita a inscrição e retorna uma notificação contendo o cupom promocional `SIGNUP30`, que oferece 30% de desconto em qualquer compra no checkout.

10. Aplicação do Cupom de Desconto ao Carrinho



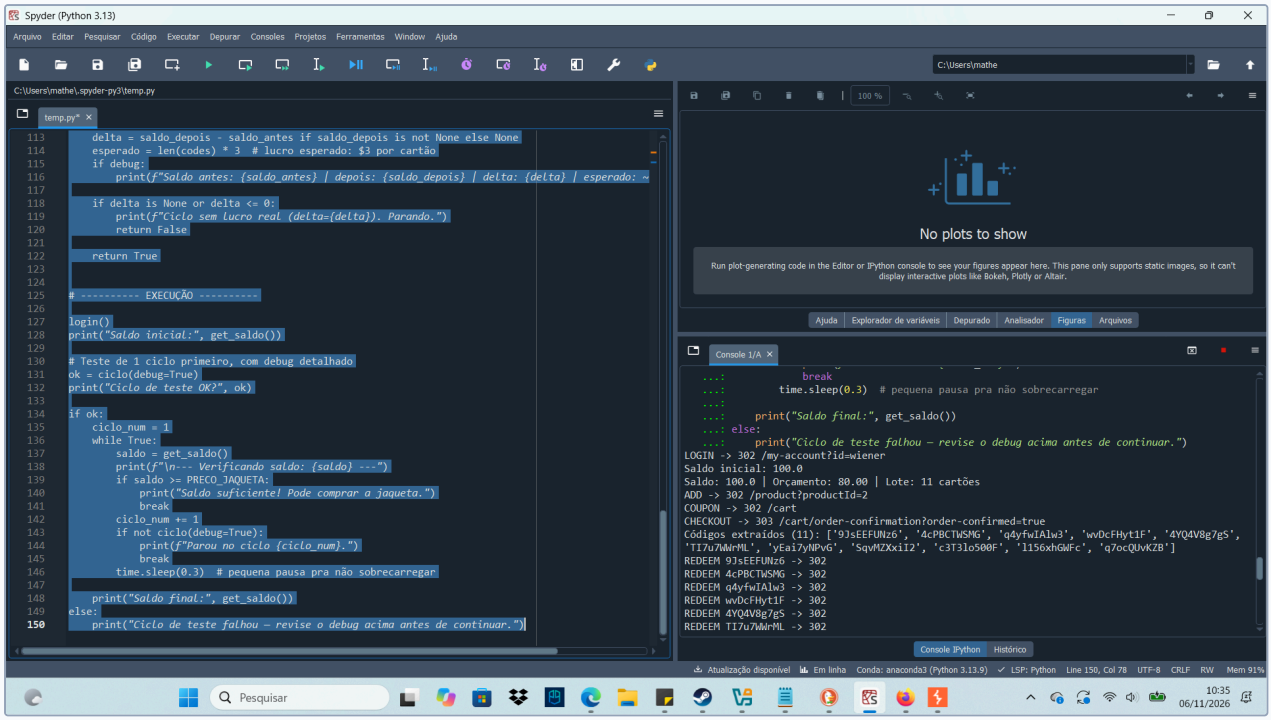
Ao aplicar o cupom `SIGNUP30` na compra do Gift Card de $10,00, o total a pagar é reduzido para $7,00 (desconto de $3,00). No entanto, o valor de resgate do cartão permanece em $10,00, gerando um lucro líquido de $3,00 por ciclo.

11. Teste de Escala em Outros Produtos



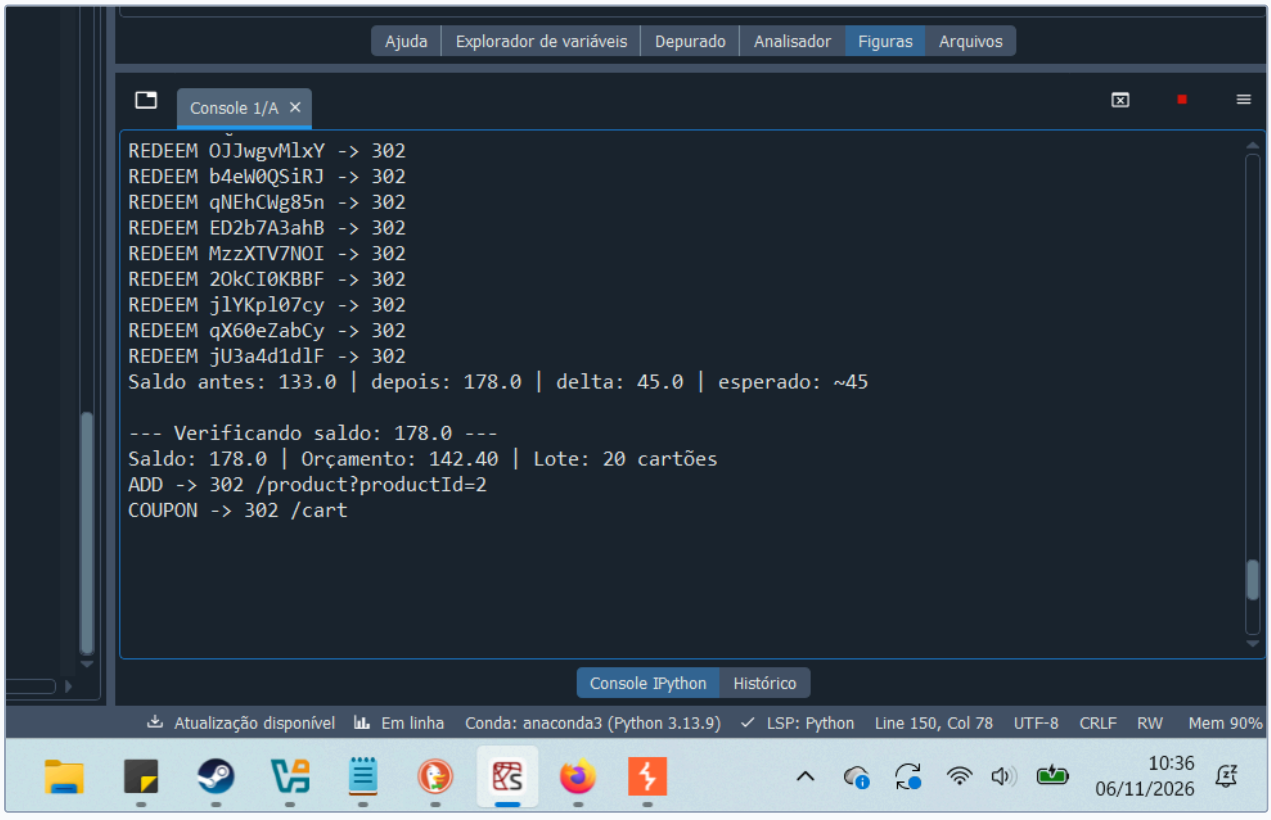
Validação da regra de negócio: a aplicação do cupom funciona de forma percentual generalizada, confirmando que a falha reside na ausência de validação do valor do resgate versus valor pago com desconto.

12. Automação da Exploração em Python (IDE Spyder)



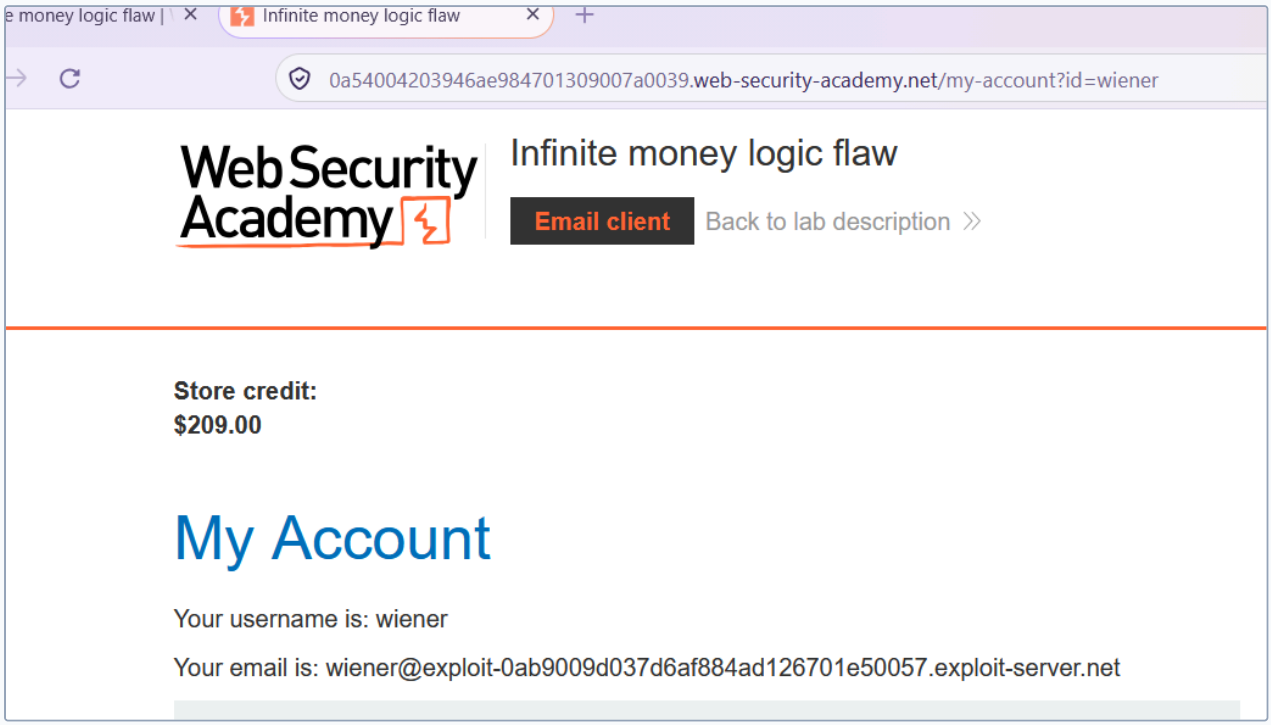
Como o Burp Suite Community possui limitação de taxa no Intruder, utilizou-se um script Python (desenvolvido com suporte do Claude) no Spyder. O script autentica, compra lotes de Gift Cards com cupom, extrai os códigos das respostas HTTP e faz o resgate automático em loop.

13. Monitoramento em Tempo Real dos Ciclos de Lucro



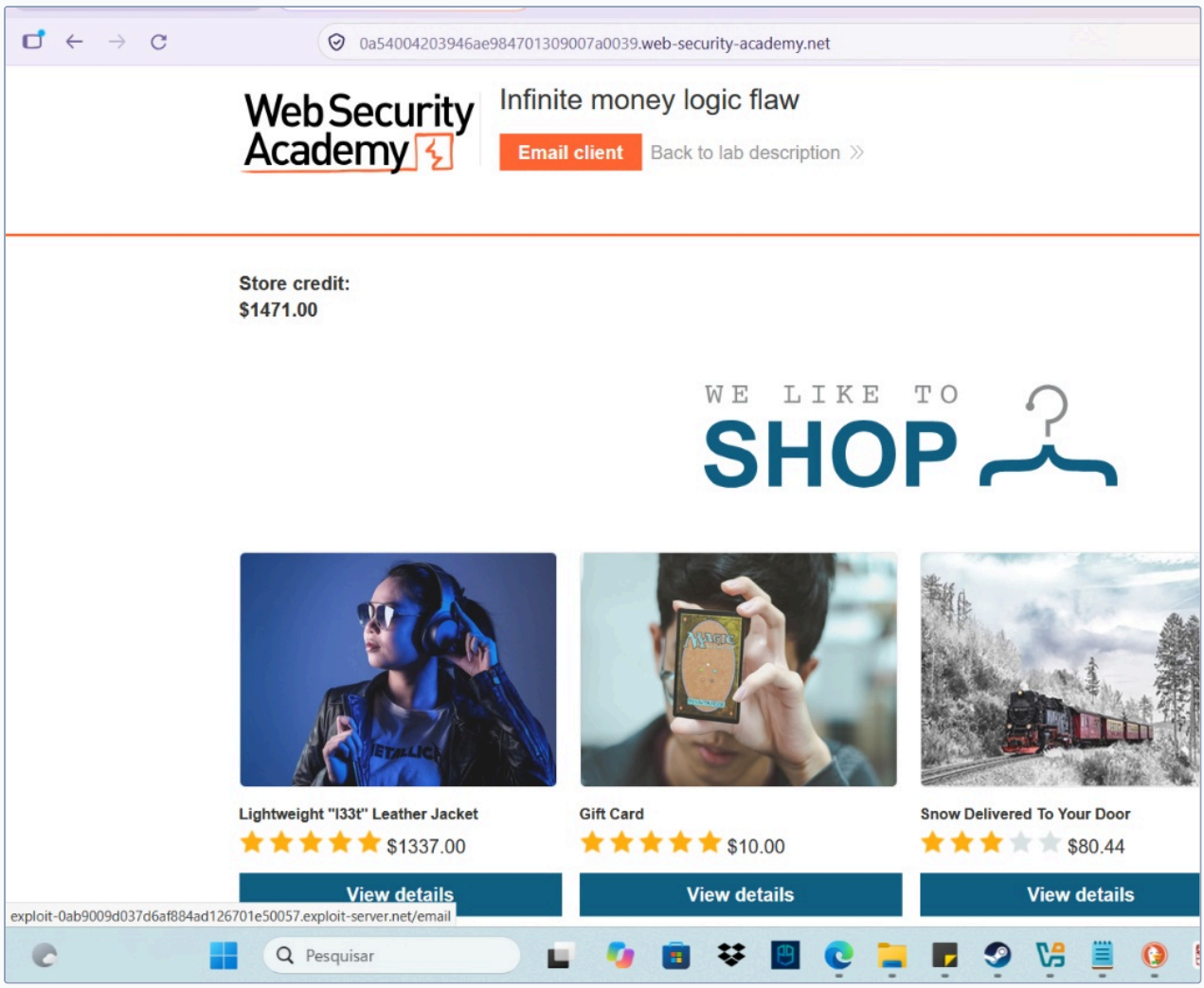
Console do Spyder exibindo a execução em lote das requisições `REDEEM -> 302`. O log confirma a escalada progressiva do saldo: de $133,00 para $178,00 e expandindo o tamanho do lote para 20 cartões por ciclo.

- **14. Confirmação do Saldo Automatizado ($209,00)**



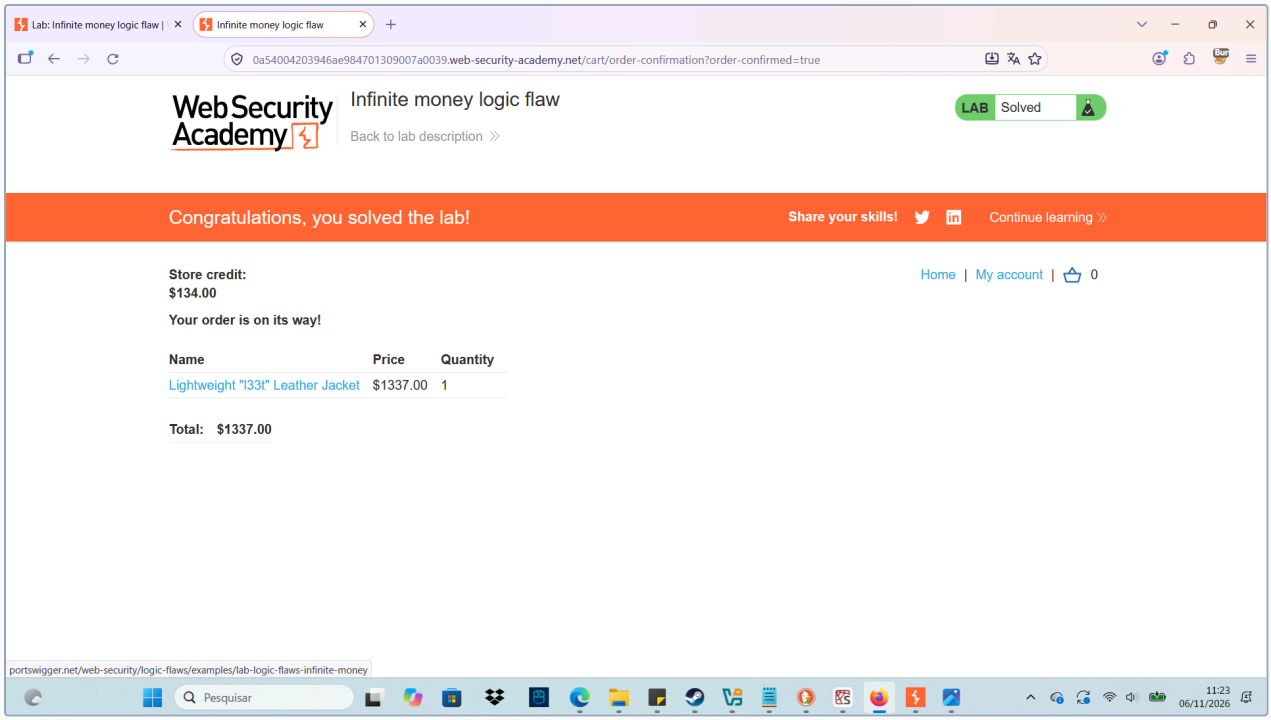
Verificação no navegador após os primeiros ciclos do script: o saldo no painel `My Account` atinge $209,00, demonstrando o crescimento exponencial dos lucros sem intervenção manual.

- **15. Acúmulo de Crédito Suficiente ($1471,00)**



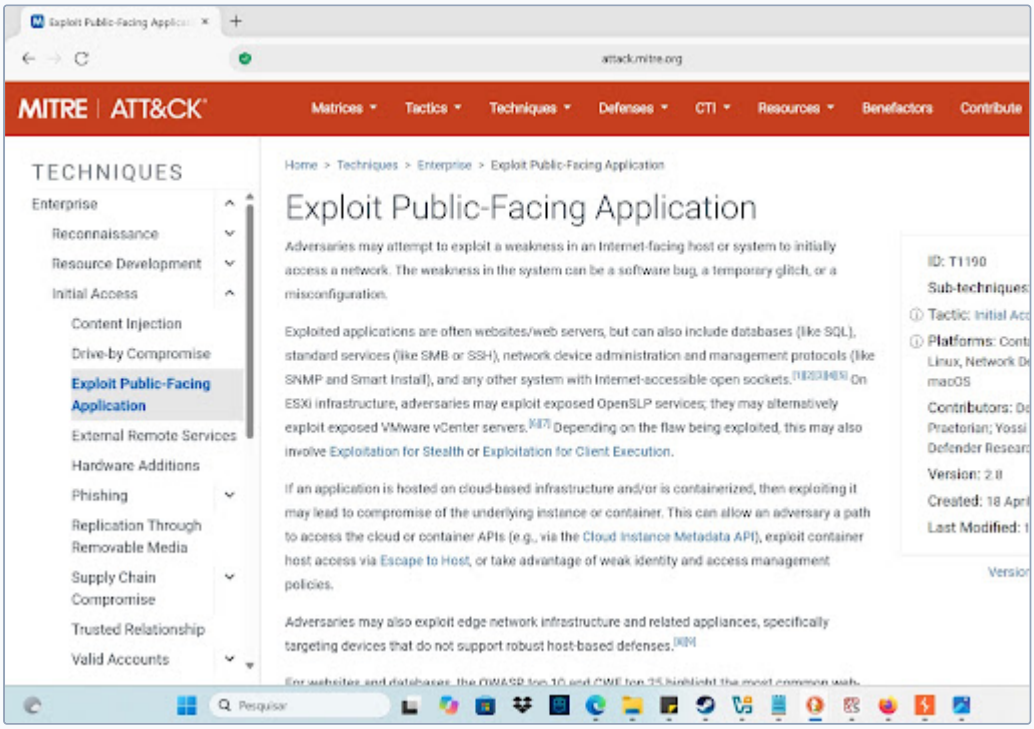
Após deixar a automação Python rodar até ultrapassar o alvo, a loja exibe um saldo de **$1471,00** na conta — valor mais do que suficiente para comprar a jaqueta de $1337,00.

16. Compra Final e Resolução do Laboratório



Compra da "Lightweight 133t Leather Jacket" concluída com sucesso utilizando o saldo acumulado. A aplicação exibe a mensagem de confirmação **"Congratulations, you solved the lab!"**, validando a exploração bem-sucedida através da automação em Python.

17. Mapeamento de TTP - MITRE ATT&CK (T1190)



Justificativa da escolha do TTP: Sob o framework **MITRE ATT&CK (Enterprise)**, a exploração dessa vulnerabilidade se enquadra na técnica **T1190 - Exploit Public-Facing Application** (Tática: *Initial Access*). A escolha se justifica pois o vetor de ataque utiliza a interface pública e exposta da aplicação web (endpoints HTTP do e-commerce) para abusar de uma falha de lógica de negócio e controle de estado financeiro, permitindo que o adversário obtenha vantagem indevida e execute ações não autorizadas a partir da própria infraestrutura exposta na internet.